

Customer-Facing Compliance Report

Framework: HIPAA Security Rule - 2025 Notice of Proposed Rulemaking (NPRM)

Primary audience: Healthcare covered entities, business associates, compliance leaders, and security architects preparing for the 2025 NPRM and tracking implementation expectations.

CSW positioning: Proposed mandatory network segmentation, technology asset inventory expansion, longer audit-trail retention architecture, 72-hour breach timeline support, and annual technical assessment evidence.

Framework Version Note

This report references the HIPAA Security Rule 2025 NPRM published by HHS / OCR. The NPRM is a PROPOSED rule. Final rule text, effective dates, and implementation expectations may differ from the NPRM. Revalidate this mapping after final rulemaking. Specific section references (e.g. proposed 45 CFR 164.312(a)(2)(vi) network segmentation; 24-month audit trail retention; 72-hour breach timeline) reflect the proposed-rule language at the time of writing.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-HIPAA-NPRM-Technical-Runbook.md) in this folder contains the deeper engineering detail.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW "certifies" compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer's compliance team, and the customer's assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does not replace the customer's governance, policy, or assessor judgement, and this report is not a control attestation.

Suggested CSW Scope Pattern

“

HIPAA-2025-NPRM

??? ePHI-Systems

??? Network-Segmentation-Boundary

??? Technology-Asset-Inventory

??? Audit-Trail-Sources

??? Incident-Timeline

,

This scope pattern should be validated with the customer's architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- ? Proposed network segmentation requirement (workload-to-workload allowlist)
- ? Proposed expanded technology asset inventory (workload + software inventory)
- ? Proposed longer audit-trail retention (architecture / evidence inputs)
- ? Proposed 72-hour breach timeline (forensic input)
- ? Proposed annual technical assessment (continuous evidence)

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- ? Privacy Rule provisions
- ? Business Associate Agreement (BAA) lifecycle
- ? Identity and access management beyond workload-to-workload
- ? Encryption enforcement (CSW detects plaintext but does not enforce encryption)
- ? Final OCR / HHS interpretive guidance and enforcement decisions

Framework Topic ? CSW Capability Map

Framework topic	CSW capability	Evidence artifact
	Proposed mandatory network segmentation	Policy workspace + workload-to-workload allowlist
	Proposed expanded technology asset inventory	Workspace snapshot + observed-vs-approved flow comparison
	Proposed audit-trail retention	Workload inventory + software / package inventory
	Proposed 72-hour breach timeline	Inventory and software-package extract reconciled to CMDB
	Proposed annual technical assessment	Workload flow + process telemetry retained per longer retention window
		Retained telemetry export with retention attestation
		Forensic flow + process search across the incident window
		Investigation pack with timeline and ePHI-system-impact scope
		Continuous policy + ADM + vulnerability evidence
		Annual evidence bundle

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
	ePHI system inventory	Workloads handling ePHI	Inventory + scope membership export filtered by data_class=ephi
			Monthly

Segmentation evidence	Workspace snapshot + observed-vs-approved flow comparison	Policy workspace export + ADM export	Quarterly + after each change
Technology asset inventory	Workload + software inventory aligned to proposed inventory expansion	Inventory + software/package extract	Monthly
Audit-trail retention	Workload flow + process telemetry over the proposed retention window	Retained telemetry export with retention attestation	Continuous; validated annually
Vulnerability + reachability	CVE list weighted by reach into ePHI systems	Vulnerability report scoped to HIPAA-2025-NPRM	Monthly
Breach timeline sample	Workload-level timeline for one representative incident	Flow + process search	Per breach
Annual technical assessment pack	Aggregated annual evidence bundle	Inventory + workspace + ADM + vulnerability + incident-sample extracts	Annually

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, np, cui, ephi').
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

This mapping reflects a PROPOSED rule and must be revalidated against the final rule. CSW does not replace legal analysis, HIPAA policies, the risk analysis itself, BAA management, identity / authentication, encryption enforcement, breach-notification decisions, or OCR enforcement engagement.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.